HL-CYB-001

Focused security requirements and threat model

Enterprise Zero Trust Security Architecture

Document version 3621e5a333db

PLANNED - operational controls NOT TESTED

T6 baseline, 2026-11-06. Controls PLANNED; operational effectiveness NOT TESTED.

The lab must let approved people use one synthetic application without exposing administration, other resources or protected networks. These controls implement the assignment in the three-zone architecture. They are educational engineering controls, not a compliance certification.

1. Assets, actors, and boundaries

Protect the home/production boundary, privileged access, lab passwords, CA/server keys, synthetic application data, logs, backup media and public repository. Consider an unassigned user, stolen lab credentials, a compromised endpoint or overlay device, administrator error and a leaked artifact. Boundaries are Management versus workloads, Corporate versus Restricted, same-zone host access, application roles, Tailscale versus APP1 and private records versus public Git.

One hypervisor/admin compromise can defeat virtual separation. A single host has no availability guarantee. Network permits, valid certificates and successful AD logons do not by themselves grant application permission. Apache roles are manually mapped to AD roles; no live synchronization or universal MFA is claimed.

2. Mandatory security requirements

New FSC IDs avoid reusing historical S01-S12 with changed meaning.

Table 1. Mandatory security requirements

Security ID	Measurable control	Requirements / tests
FSC-01	No production/home trust, data, identities, credentials or unapproved connectivity. Keep uplinks disconnected until an independently isolated design is approved; inspect adapters/routes/IPv6 and prove a lab mock denial.	FWR-01; FWT-01
FSC-02	Three zones, default-deny routed access, narrow named services, protected management and console recovery; audit automatic rules, existing state and same-zone host policy.	FWR-02; FWT-02
FSC-03	Three standard users/role groups, one separate privileged administrator; six effective app role cases and app access revocation. Audit manual AD-to-app mapping and separate passwords.	FWR-03; FWT-03
FSC-04	Supported Windows/Linux builds, recorded update status, enabled host firewalls, single zone NICs and no ordinary-user admin rights; restrict the approved APP1 overlay separately.	FWR-04; FWT-04
FSC-05	One CA and HTTPS leaf; protect key files, restrict CA trust to lab clients and verify hostname/chain/validity plus untrusted-client rejection.	FWR-05; FWT-05
FSC-06	Separate lab Tailscale identities/tailnet, supported MFA/recovery, only APP1 TCP 443, no routes/exit node/public share; deny wrong-resource/port access and demonstrate revoked access.	FWR-06; FWT-06
FSC-07	Two or three relevant local log sources, five benign events, UTC/time notes, restricted record access/rotation and one investigated denial. No password/token content in logs.	FWR-07; FWT-07

Security ID	Measurable control	Requirements / tests
FSC-08	One reviewed PowerShell/Python operation with explicit local target, private output, safe rejection and repeat execution; inspect actual state separately.	FWR-08; FWT-08
FSC-09	One encrypted off-compute APP1 backup, private key custody, isolated successful restore, actual elapsed time and integrity/function checks. Never overwrite the only backup or run duplicated overlay identities.	FWR-09; FWT-09
FSC-10	Review every public artifact/history; exclude credentials, actual addresses, private inventories, tenant IDs, raw logs, backups and production/proprietary content. Read-only pinned CI, scope-specific approvals and separate owner UAT.	FWR-10; FWT-10

DNS clients use the lab resolver, with no corporate suffix/forwarding. Only approved components receive scoped egress; firewall-originated traffic also follows protected-destination restrictions. No test targets real protected networks. Software installation, disk selection, trust changes and remote enrollment need the relevant explicit owner approval.

3. Threat-to-control mapping

Table 2. Threat-to-control mapping

Threat	Control / safe verification	Residual limit
Accidental bridge/route reaches protected assets	FSC-01/02; cable/configuration review plus lab-owned mock denial	Shared home uplink cannot prove independence; DEC-03 blocks online work
Ordinary user gains extra application/admin rights	FSC-02/03/04; six app cases, host/management denial and revocation	Same-zone/overlay paths bypass OPNsense; inspect effective host/application policy
Credentials or CA keys are stolen	FSC-03/05/06/10; separate secrets, encrypted CA custody and scoped MFA	Single operator, manual role mapping and no hardware key module
Remote enrollment exposes more than APP1	FSC-06; effective vendor/host rule inspection and actual denied-port/revocation cases	Provider features, cached state and rule precedence need current verification
Missing/misleading logs hide a denial	FSC-07; compare source event to observed action and investigate the exact policy	Small manual sample, no enterprise detection/retention coverage
Automation or restore damages the lab	FSC-08/09; local target rejection, repeat-run inspection and disconnected restore	APP1 restore does not establish AD/CA/host disaster recovery
Public evidence discloses private information or overstates results	FSC-10; full-content/metadata and Git history review plus focused scanner	Scanner coverage is bounded; publication operator remains responsible

4. Historical control transition

The historical S IDs remain in frozen evidence and T5 Office templates. They are not current extra requirements.

Table 3. Historical control transition

Earlier controls	Current controls / disposition
S01, S06	FSC-01/02/04; default deny, scoped DNS and host boundaries retained
S02, S03	FSC-01/03/04; role model reduced to approved counts
S04, S09	FSC-02/06; supported management/remote MFA and one-resource Tailscale
S05	FSC-05; one CA/leaf, basic trust/expiry; separate issuer/revocation service retired
S07, S10, S12	FSC-10 plus FSC-01/02/04; public hygiene, verified media, stage approval and UAT separation
S08	FSC-07; small relevant event sample replaces enterprise collection targets
S11	FSC-09; one demonstrated application restore replaces broader recovery objectives

NIST SP 800-207 is the conceptual reference for resource-focused verification. The earlier detailed NIST/CIS mappings are preserved in Git history; no full control/baseline coverage is required. The reference catalog links primary guidance.

5. Publication and incident handling

Keep raw evidence and working submissions outside Git. Before each publication inspect the entire candidate/staged set, filenames, metadata and new history; run focused checks and manually read artifacts. Ignore rules do not remove tracked secrets. Do not bypass a finding. Stop publication on exposure; follow the owner's authorized revoke/rotate process and obtain approval before history rewriting. T6 authorizes no production incident action.